15 Security, zero trust, and authorization

This chapter covers

- Why Zero Trust shifts security focus from network boundaries to authorization
- How PBAC enables continuous, context-aware access decisions
- The roles of foundational, shared operational, and application policies in a zero-trust architecture
- How policy engines evaluate these policies together to ensure consistent access control
- Architectural and organizational metrics indicating progress toward Zero Trust

ACME's Chief Information Security Officer, Sam, had grown weary of hearing the same refrain. Every conference keynote, board meeting, and analyst report seemed to boil modern security down to two words: *Zero Trust*. The phrase was everywhere—sometimes used thoughtfully, often as a slogan—but rarely with enough detail to help him lead meaningful change. After one particularly pointed board meeting, Sam went back to his security team and said, for what felt like the tenth time, "We need to get serious about Zero Trust. What does that actually mean for us?"

The team's early efforts yielded familiar solutions: network segmentation, VPN tightening, endpoint monitoring, stronger passwords, and micro-perimeters. However, none of these addressed the core issue: ACME was no longer a company with a clear perimeter defining what was inside and what was out. The workforce was global, systems were distributed across several different clouds, and the Customer Collaboration platform served thousands of external customers. The security team kept circling the same conclusion: The perimeter era was over, and no amount of firewall tuning would bring it back.